3. Complete System Architecture and Detailed Design

HackTheAPI // OWASP API Security Training & Assessment Platform

---

■■ 1. High-Level System Topology

HackTheAPI is built on a 5-layer decoupled architecture separating the Client UI, Security Gateway, Backend REST Services, Container Workspaces, and Local AI Engine.

```
flowchart TB
    subgraph CLIENT_LAYER["Client Layer (React 18 SPA - Port 3009)"]
        UI["React Frontend Dashboard / Modules"]
        QB["Target OpenAPI Payload Workbench"]
        QWEN_UI["VS Code Copilot Style Qwen AI Panel"]
        DOM_SYNC["Real-Time Screen & Workbench Context Reader"]
    end

    subgraph GATEWAY_LAYER["Transport & Security Gateway"]
        NGINX["Nginx / Cloudflare Tunnel Gateway"]
        CORS_GATEWAY["CORS & Bearer Security Filter"]
    end

    subgraph BACKEND_LAYER["Backend Core Layer (Django REST Framework - Port 8000)"]
        AUTH_MODULE["Obj 1: Auth & Role Engine (JWT / RBAC / Gmail SMTP)"]
        EXERCISE_CATALOG["Obj 2: Lab Catalog Manager (12 OWASP Labs)"]
        ORACLE_ENGINE["Obj 3: Independent Oracle Verification Engine"]
        ASSESSMENT_ENGINE["Obj 4: Transfer Learning & Analytics Engine"]
        AI_GATEWAY["Obj 5: Qwen AI Context Orchestrator"]
    end

    subgraph ISOLATED_LABS["Isolated Container Workspaces (Docker Subnet)"]
        LAB_CONTAINER_1["Container Session #1 (Port 8101 - BOLA)"]
        LAB_CONTAINER_2["Container Session #2 (Port 8102 - BFLA)"]
        LAB_CONTAINER_N["Container Sessions #3..12 (Isolated Ports)"]
    end

    subgraph AI_ENGINE["Local AI Engine (Port 11434)"]
        OLLAMA["Local Ollama LLM Service (qwen2.5-coder)"]
    end

    subgraph DB_LAYER["Persistence Layer"]
        SQLITE_DB[("SQLite / PostgreSQL Database")]
    end

    UI --> NGINX
    NGINX --> CORS_GATEWAY
    CORS_GATEWAY --> BACKEND_LAYER

    QB -->|HTTP Payloads| LAB_CONTAINER_1
    QB -->|HTTP Payloads| LAB_CONTAINER_2

    ORACLE_ENGINE -->|Verification Inspections| LAB_CONTAINER_1
    ORACLE_ENGINE -->|Verification Inspections| LAB_CONTAINER_2
    ORACLE_ENGINE -->|Record Score & Audit Log| SQLITE_DB

    AUTH_MODULE -->|User Roles & 3-Attempt Tokens| SQLITE_DB
    ASSESSMENT_ENGINE -->|Pre/Post Metrics| SQLITE_DB

    DOM_SYNC -->|Screen Context & Request Builder State| QWEN_UI
    QWEN_UI -->|Chat Request + Page Context| AI_GATEWAY
```

```
    AI_GATEWAY -->|User Progress + Screen State| OLLAMA
    OLLAMA -->|Intelligent Hints & Step Guidance| AI_GATEWAY
    AI_GATEWAY --> QWEN_UI
```

■ 2. Detailed 5-Objective Architecture Mapping

Objective 1: Multi-Tenant RBAC & Auth Sequence

```
sequenceDiagram
    autonumber
    actor User as Student / Instructor / Admin
    participant SPA as React Frontend (:3009)
    participant API as Django REST Backend (:8000)
    participant SMTP as Gmail SMTP (:587)
    participant DB as System Database

    User->>SPA: Submit Login Credentials
    SPA->>API: POST /api/v1/auth/user/login
    API->>DB: Validate Username & Password Hash
    DB-->>API: User Record & Role Claims
    API-->>SPA: Return JWT Access & Refresh Tokens

    Note over User, SMTP: Password Reset Flow (3-Attempt Threshold)
    User->>SPA: Request Password Reset
    SPA->>API: POST /api/v1/auth/reset-password/request
    API->>SMTP: Dispatch 6-Digit OTP Token
    SMTP-->>User: Deliver Verification Email
    User->>SPA: Submit Verification Code
    SPA->>API: POST /api/v1/auth/reset-password/confirm
    alt Attempt <= 3 and Code Correct
        API->>DB: Update Password Hash & Nullify Token
        API-->>SPA: Password Successfully Updated
    else Attempt > 3 or Code Invalid
        API->>DB: Increment failed_attempts; Revoke Token
        API-->>SPA: Token Revoked (Too Many Attempts)
    end
```

Objective 3 & 5: Oracle Verification & Ollama AI Sequence

```
sequenceDiagram
    autonumber
    actor Student as Student Browser
    participant SPA as React Frontend
    participant Backend as Django REST Backend
    participant Oracle as Server-Side Oracle Engine
    participant Container as Docker Target Lab
    participant Ollama as Local Ollama LLM (:11434)

    Note over Student, Container: Lab Execution & Oracle Evaluation
    Student->>SPA: Send Exploit Payload in Workbench
    SPA->>Container: HTTP Request (e.g. DELETE /api/v1/users/carlos)
    Container-->>SPA: HTTP 200 OK Response
    Student->>SPA: Click "Validate Lab"
    SPA->>Backend: POST /api/v1/labs/ex-bfla-01/submit
    Backend->>Oracle: Trigger Dual Evaluator Check
    Oracle->>Container: Inspect Database & File System State
    Container-->>Oracle: State Confirmed (User Carlos Deleted)
    Oracle-->>Backend: Result: VERIFIED_SUCCESS (Score +100)
    Backend-->>SPA: Lab Completed Successfully

    Note over Student, Ollama: Contextual AI Assistance
    Student->>SPA: Click Qwen AI Assistant ("guide me through this")
    SPA->>SPA: Capture window.__CURRENT_LAB_WORKBENCH_STATE__
    SPA->>Backend: POST /api/v1/ai/chat (Message + Full Page Context)
    Backend->>Ollama: POST /api/generate (Progress + Screen State + Prompt)
    Ollama-->>Backend: Tailored Step-by-Step Guidance
    Backend-->>SPA: Display Guidance in AI Drawer
```

■■ 3. Database Entity-Relationship Diagram (ERD)

```
erDiagram
    USER {
        int id PK
        string username
        string email
        string role "Student | Instructor | Assessor | Admin"
        boolean is_active
        datetime date_joined
    }

    USER_PROGRESS {
        int id PK
        string user_email FK
        string exercise_id
        string status "NOT_STARTED | IN_PROGRESS | COMPLETED"
        int score
        datetime completed_at
    }

    USER_LAB_SESSION {
        int id PK
        string user_email FK
        string exercise_id
        int assigned_port
        string status "RUNNING | PAUSED | STOPPED"
        datetime started_at
        datetime expires_at
    }

    USER_AI_CONVERSATION {
        int id PK
        string user_email FK
        string role "user | assistant"
        text message
        datetime timestamp
    }

    PASSWORD_RESET_TOKEN {
        int id PK
        string email FK
        string token
        int failed_attempts
        boolean is_used
        datetime expires_at
    }

    SECURITY_AUDIT_LOG {
        int id PK
        string user_email FK
        string event_type
        string ip_address
        datetime timestamp
    }

    USER ||--o{ USER_PROGRESS : tracks
    USER ||--o{ USER_LAB_SESSION : owns
    USER ||--o{ USER_AI_CONVERSATION : conducts
    USER ||--o{ PASSWORD_RESET_TOKEN : requests
    USER ||--o{ SECURITY_AUDIT_LOG : generates
```

■ 4. Network Port Matrix

Service Component	Port	Network Interface	Protocol	Description
Vite React Frontend	`3009`	`0.0.0.0`	HTTP / WebSockets	Client UI SPA
Django REST Backend	`8000`	`127.0.0.1`	HTTP	Backend API Core
Local Ollama Service	`11434`	`127.0.0.1`	HTTP / JSON	Local LLM (`qwen2.5-coder`)
Target Lab Workspaces	`8101 - 8112`	`127.0.0.1`	HTTP	Docker Target Lab Containers